

INFORMÁTICA FORENSE

INTRODUCCIÓN A LA INFORMÁTICA FORENSE

Elevator Pitch Forense

40 segundos por alumno — Responde solo estas 3 preguntas:

1

Nombre / Cargo actual

Preséntate con tu nombre completo e indica tu cargo dentro de la institución.

2

Nivel de Experiencia Forense

Escala del 1 al 5:

1 = Curiosidad

5 = Perito activo

3

Una Expectativa Específica

¿Qué problema técnico u operativo quieres resolver al terminar este curso?

Contenido de la Sesión

1.1 Incidentes de Seguridad

1.2 Definición y Alcance de la Informática Forense

1.3 Tipos de Evidencia Digital

1.4 Normas ISO y Marco Regulatorio Nacional

1.5 El Proceso de Cómputo Forense

1.6 Aplicación: Casos Ilustrativos

SECCIÓN 1.1

Incidentes de Seguridad

Definiciones, tipología de amenazas y marco legal aplicable

Evento vs. Incidente de Seguridad

EVENTO

Definición

Cualquier suceso observable en un sistema o red que es detectado por mecanismos de monitoreo.

Características

- Registro en logs del sistema
- Alerta generada por IDS/IPS
- No necesariamente implica daño
- Requiere análisis para clasificación

INCIDENTE

Definición

Compromiso confirmado de la confidencialidad, integridad o disponibilidad de la información institucional.

Características

- Impacto negativo confirmado
- Requiere respuesta inmediata
- Activa protocolos de IR
- Puede tener implicancias legales

Tipología de Amenazas



Acceso No Autorizado

Intrusión a sistemas sin credenciales válidas. Incluye ataques de fuerza bruta, explotación de vulnerabilidades y escalamiento de privilegios.



Exfiltración de Información

Extracción no autorizada de datos sensibles o clasificados fuera del perímetro institucional mediante canales encubiertos o dispositivos removibles.



Malware / APT

Amenazas Persistentes Avanzadas y software malicioso diseñado para comprometer sistemas militares de forma sigilosa y prolongada.



Amenazas Internas (Insider)

Personal con acceso legítimo que, de forma intencional o negligente, compromete la seguridad de la información institucional.

Ciclo de Vida del Incidente

1

Preparación

Establecimiento de políticas, equipos CSIRT y herramientas de monitoreo continuo.

2

Detección

Identificación de anomalías mediante SIEM, IDS/IPS y análisis de comportamiento.

3

Contención

Aislamiento del sistema comprometido para evitar la propagación lateral.

4

Erradicación

Eliminación de la causa raíz: malware, accesos no autorizados, vulnerabilidades.

5

Recuperación

Restauración de sistemas y verificación de integridad operacional.

LEY N.° 30096

LEY DE DELITOS INFORMÁTICOS

Delitos Informáticos

- Acceso ilícito a sistemas informáticos
- Atentado contra la integridad de datos y sistemas
- Interceptación de datos informáticos
- Fraude informático
- Suplantación de identidad

Modificada por Ley N.° 30171

SECCIÓN 1.2

Definición y Alcance de la Informática Forense

Disciplina científica, principios rectores y relación con otras áreas

Informática Forense: Concepto y Dimensión Jurídica

CONCEPTO TÉCNICO

Disciplina científica orientada a:

- Identificación de fuentes de evidencia digital
- Preservación íntegra de los datos originales
- Análisis técnico de artefactos digitales
- Presentación de hallazgos ante autoridades

El proceso de investigación de los sistemas de información para detectar toda evidencia que pueda ser presentada como medio de prueba fehaciente para la resolución de un litigio dentro de un procedimiento judicial.

Método científico aplicado a la evidencia digital

DIMENSIÓN JURÍDICA

Principio de intercambio de Locard:

"Todo contacto deja rastro" — aplicado al entorno digital

- El hallazgo técnico debe tener validez legal
- Cadena de custodia documentada
- Reproducibilidad del análisis
- Perito forense como testigo experto

Principios Rectores de la Informática Forense



Reproducibilidad

Todo procedimiento forense debe poder ser replicado por un tercero independiente, obteniendo los mismos resultados bajo las mismas condiciones.



Integridad

Garantizar que la evidencia digital no ha sido alterada desde su recolección. Se verifica mediante funciones hash criptográficas (SHA-256, MD5).



Trazabilidad

Documentación completa de cada acción realizada sobre la evidencia: quién, cuándo, qué y cómo. Sustenta la cadena de custodia.

Objetivo de la informática forense



Análisis Reactivo vs. Proactivo

ANÁLISIS REACTIVO

Post-incidente

- Se activa después de detectar un incidente
- Busca determinar el alcance del daño
- Identifica al responsable y el vector de ataque
- Genera evidencia para procesos legales
- Alimenta lecciones aprendidas

ANÁLISIS PROACTIVO

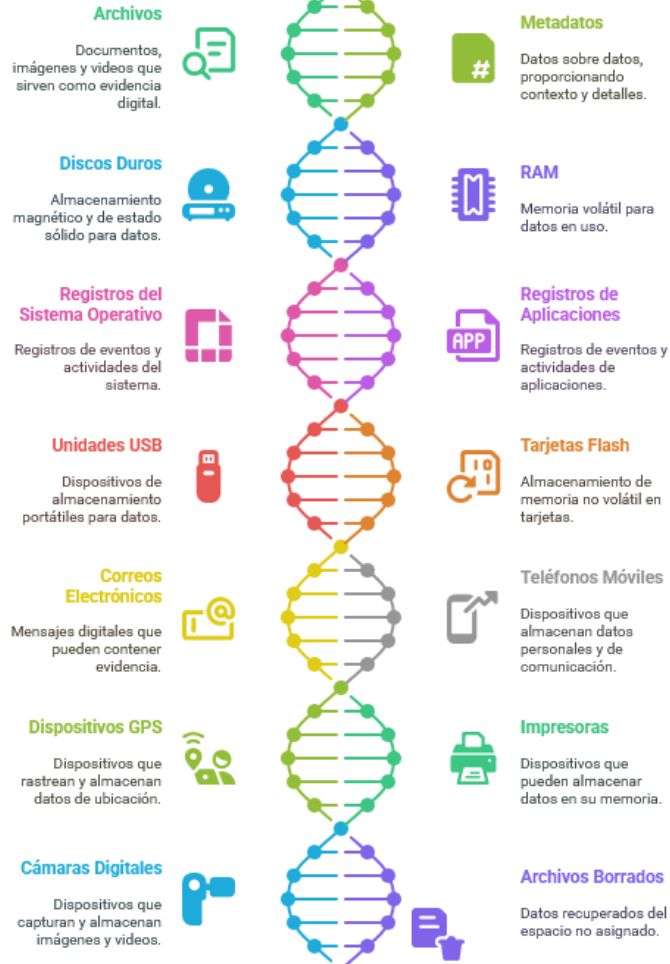
Threat Hunting

- Búsqueda activa sin incidente confirmado
- Basado en hipótesis e inteligencia de amenazas
- Detecta amenazas latentes o APTs
- Mejora continua de las defensas
- Reduce el tiempo de permanencia del atacante

SECCIÓN 1.3

Tipos de Evidencia Digital

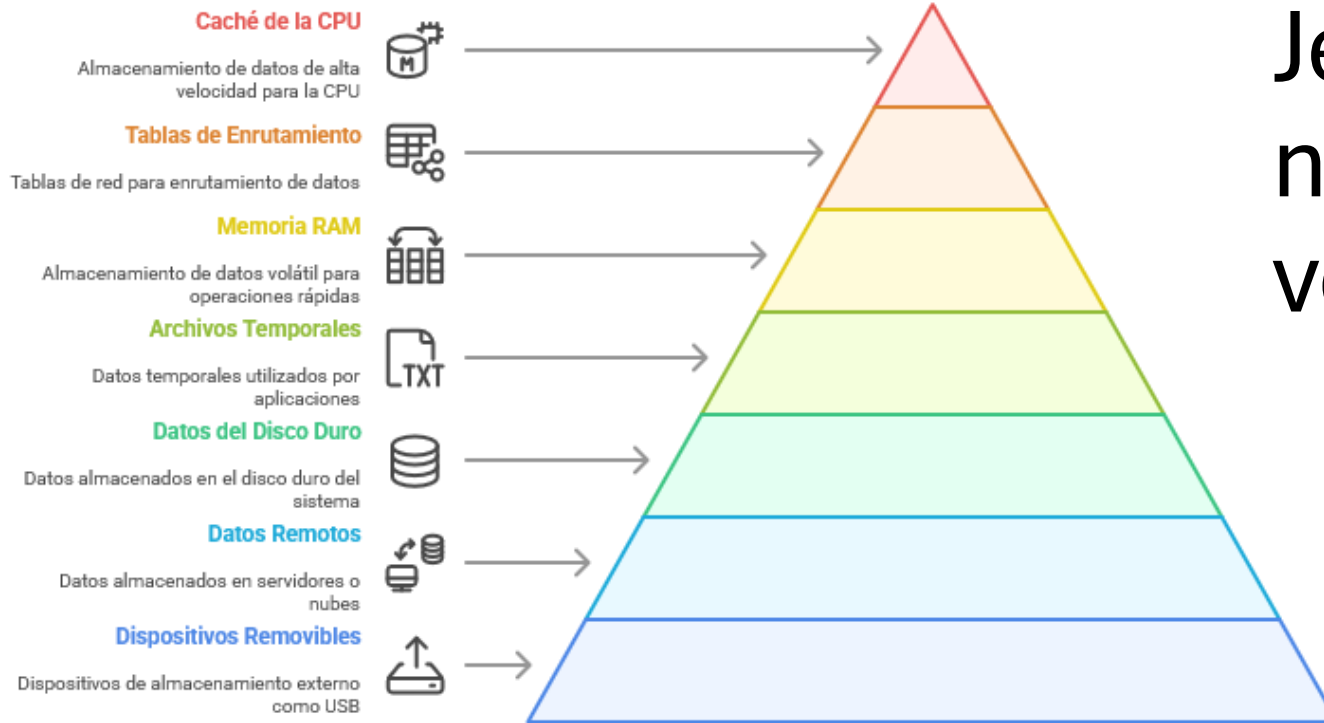
Clasificación, volatilidad y criterios de admisibilidad



Evidencia digital en la informática forense

Todo elemento que pueda almacenar información en formato electrónico, de forma física o lógica y que permita constatar un hecho investigado o el esclarecimiento del mismo.

Jerarquía de nivel de volatilidad



Clasificación Técnica de Artefactos

OS Artifacts

Registro de Windows, prefetch, shellbags, MFT, event logs, jump lists

Red (PCAP)

Capturas de tráfico, flujos NetFlow, logs de firewall, registros DNS, logs de proxy

Aplicaciones

Logs de servidores web, bases de datos, correo electrónico, aplicaciones militares específicas

Datos de Usuario

Documentos, historial de navegación, correos, chats, archivos multimedia, descargas

Entornos Modernos y Admisibilidad

EVIDENCIA EN LA NUBE Y MÓVILES

Cloud Computing

- Logs de proveedor (AWS, Azure), snapshots de VM, registros de acceso IAM

Dispositivos Móviles

- Datos de geolocalización, mensajería, registros de llamadas, aplicaciones instaladas

Desafíos: jurisdicción, cifrado y volatilidad de datos en la nube

CRITERIOS DE ADMISIBILIDAD

Para que la evidencia digital sea válida:

- Autenticidad: Demostrar que es genuina y no fabricada
- Integridad: Verificar que no fue alterada (hash)
- Confiabilidad: Método de obtención reconocido
- Relevancia: Pertinencia para el caso investigado

SECCIÓN 1.4

Normas ISO y Marco Regulatorio Nacional

Estándares internacionales y regulación peruana aplicable

Estándares Internacionales y Guías Técnicas

ISO/IEC 27037:2012

Directrices para la Evidencia Digital

Identificación, recolección, adquisición y preservación de evidencia digital.
Define roles DEFR y DES.

- Directrices para identificación de evidencia
- Procedimientos de recolección y preservación
- Referencia principal para procedimientos forenses

ISO/IEC 27043:2015

Procesos de Investigación de Incidentes

Marco completo del proceso investigativo digital de principio a fin.

- Fases: preparación, adquisición, análisis, reporte y cierre
- Complementa ISO 27037 con el flujo completo de investigación

ISO/IEC 27002:2022

Controles de Seguridad de la Información

Gestión de incidentes de seguridad (Cláusulas 5.24 a 5.28).

- Planificación, evaluación y respuesta a incidentes
- Aprendizaje de incidentes y recolección de evidencia

NIST SP 800-86

Guía de Integración de Técnicas Forenses

Guía del NIST para incorporar forense en la respuesta a incidentes.

- Proceso: recolección, examen, análisis y reporte
- Referencia principal del gobierno de EE.UU. para forense digital

LEY N.° 30096

LEY DE DELITOS INFORMÁTICOS

Delitos Informáticos

- Acceso ilícito a sistemas informáticos
- Atentado contra la integridad de datos y sistemas
- Interceptación de datos informáticos
- Fraude informático
- Suplantación de identidad

Modificada por Ley N.° 30171

SECCIÓN 1.5

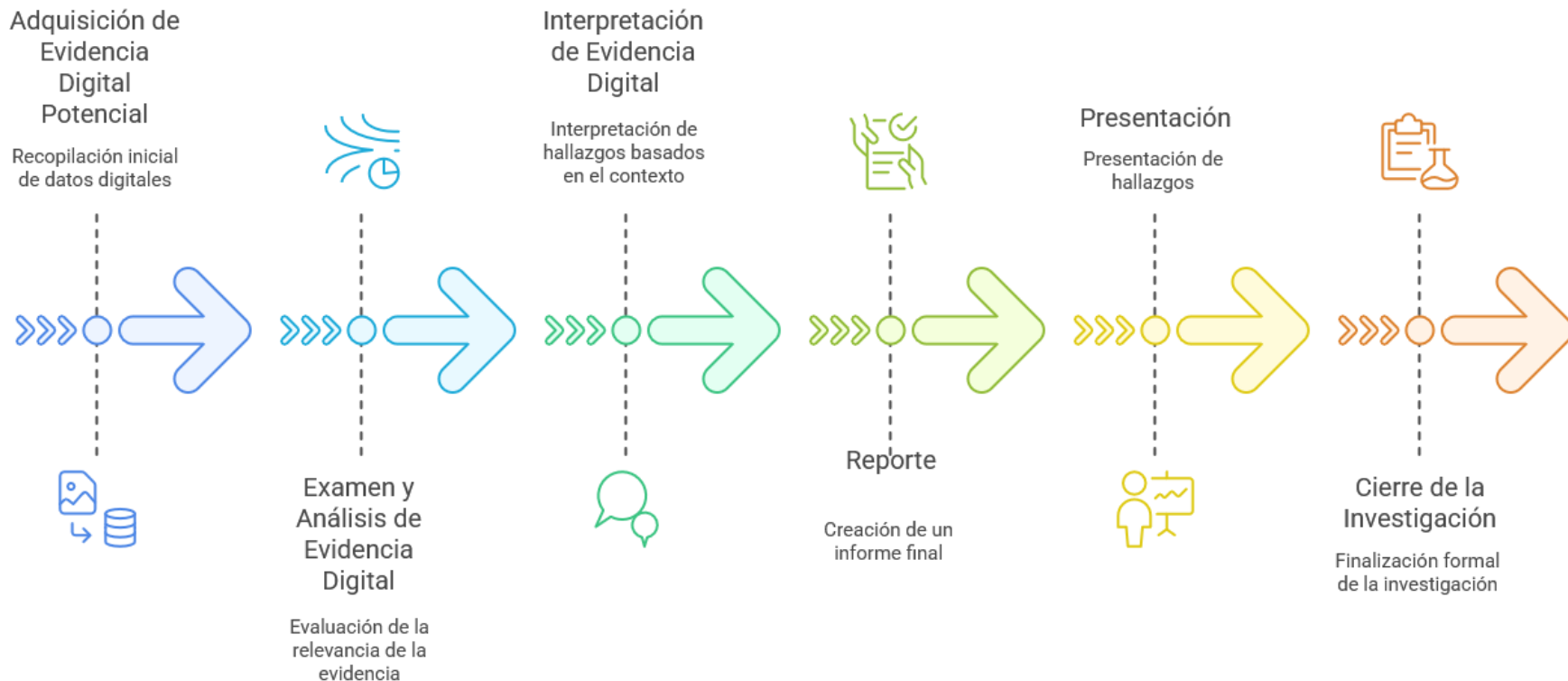
El Proceso de Cómputo Forense

Cadena de valor: identificación, adquisición, preservación, análisis y presentación

Proceso Forense Digital



Proceso Forense Digital



Fase 1: Adquisición de Evidencia Digital Potencial

OBJETIVO

Potential Digital Evidence Acquisition

- Primer paso dentro de los Procesos Investigativos según ISO/IEC 27043
- También forma parte de los Procesos Adquisitivos del modelo
- Busca obtener la evidencia digital potencial de manera forense y verificable
- Se aplican técnicas de imagen bit a bit y bloqueadores de escritura
- Debe garantizar la no alteración de los datos originales

PROCEDIMIENTO

Pasos Clave de la Adquisición

- Identificar todas las fuentes de evidencia digital relevantes
- Priorizar la adquisición según el orden de volatilidad (RFC 3227)
- Crear copias forenses exactas de los dispositivos y medios
- Calcular y registrar hashes criptográficos (SHA-256) de cada imagen
- Documentar íntegramente el proceso de adquisición realizado

Fase 2: Examen y Análisis de Evidencia Digital

- **Objetivo principal:** Evaluar la evidencia digital potencial para determinar su relevancia y valor probatorio en la investigación forense.
- **Transformación conceptual:** A partir de esta etapa, la "evidencia digital potencial" se convierte formalmente en "evidencia digital" confirmada.
- **Examen sistemático:** Se aplican técnicas forenses especializadas para extraer datos relevantes de las copias forenses adquiridas previamente.
- **Análisis de artefactos:** Incluye la revisión de metadatos, registros del sistema, logs de aplicaciones, archivos eliminados y líneas temporales de actividad.
- **Correlación de fuentes:** Los hallazgos de diferentes fuentes de evidencia se correlacionan para construir una visión integral del incidente investigado.
- **Herramientas especializadas:** Se utilizan herramientas reconocidas como Autopsy, EnCase, FTK, Volatility y Plaso para garantizar la rigurosidad del análisis.

Fase 3: Interpretación de Evidencia Digital

PROCESO INTERPRETATIVO

Digital Evidence Interpretation

- Los resultados del examen y análisis se interpretan en un contexto significativo
- La interpretación depende de la información contextual disponible
- Se consideran las circunstancias de la creación de la evidencia
- Se evalúa la relevancia de cada hallazgo para el caso investigado
- Requiere experiencia y juicio experto del perito forense

FACTORES CONTEXTUALES

Elementos para la Interpretación

- Circunstancias del incidente y cronología de eventos conocidos
- Perfil del usuario y patrones de comportamiento habitual
- Configuración del sistema y software instalado en el momento
- Relación temporal entre los artefactos digitales encontrados
- Marco legal y normativo aplicable a la investigación

Fase 4: Reporte de la Investigación

- Informe como salida principal: La interpretación de la evidencia digital forma la base del informe forense, que constituye la salida principal de todo el proceso investigativo.
- Estructura del informe: Debe incluir resumen ejecutivo, metodología empleada, hallazgos técnicos detallados, cadena de custodia y conclusiones fundamentadas.
- Objetividad y precisión: El reporte debe ser objetivo, técnicamente preciso y comprensible tanto para audiencias técnicas como para autoridades legales o de mando.
- Trazabilidad completa: Cada hallazgo reportado debe poder rastrearse hasta la evidencia original, manteniendo la cadena de integridad desde la adquisición hasta la presentación.
- Recomendaciones: El informe debe incluir recomendaciones de medidas correctivas y preventivas para evitar la recurrencia del incidente investigado.
- Conformidad normativa: El reporte debe cumplir con los requisitos de la norma ISO/IEC 27043 y la legislación aplicable del marco legal peruano (Ley N.° 30096).

Fase 5: Presentación de Hallazgos

PRESENTACIÓN FORMAL

Comunicación de Resultados

- Etapa donde se presentan formalmente los hallazgos de la investigación
- Puede realizarse ante autoridades judiciales, militares o administrativas
- Requiere comunicación clara adaptada al nivel técnico de la audiencia
- El perito forense actúa como testigo experto en su presentación
- Se responden preguntas y se defienden las conclusiones del informe

CONSIDERACIONES CLAVE

Elementos de una Presentación Efectiva

- Claridad en la exposición de la metodología y herramientas utilizadas
- Demostración de la cadena de custodia íntegra y documentada
- Visualización efectiva de la línea temporal de eventos
- Explicación del impacto y alcance del incidente investigado
- Soporte visual con capturas, diagramas y evidencia documental

Fase 6: Cierre de la Investigación

- Finalización formal: Esta fase marca la conclusión oficial del proceso investigativo según la norma ISO/IEC 27043, cerrando formalmente todas las actividades.
- Preservación de la evidencia: Se garantiza el almacenamiento seguro y a largo plazo de toda la evidencia digital y documentación asociada al caso.
- Archivo del caso: Toda la documentación generada durante la investigación se archiva de manera ordenada y accesible para futuras referencias o auditorías.
- Lecciones aprendidas: Se documentan las lecciones aprendidas del caso para mejorar los procedimientos y la capacidad de respuesta ante futuros incidentes.
- Liberación de recursos: Se liberan los recursos asignados a la investigación, incluyendo equipos, herramientas y personal técnico involucrado.
- Retroalimentación al proceso: Los resultados del cierre alimentan la mejora continua del proceso forense institucional y fortalecen la postura de ciberdefensa.

SECCIÓN 1.6

Aplicación: Casos Ilustrativos

Escenarios prácticos de informática forense en unidades del Ejército

ESCENARIO

El técnico Paredes llega lunes por la mañana y encuentra la PC del Mayor Rojas encendida, con sesión abierta y varias aplicaciones activas. Cierra todas las ventanas y apaga el equipo para ordenar antes de que llegue su jefe. El Mayor llega después y reporta sospechas de un acceso no autorizado el fin de semana.

EVIDENCIAS EN RIESGO

- Evidencia volátil: Al apagar el equipo se eliminaron los procesos activos, conexiones de red y archivos manipulados
- Memoria RAM: Se perdió la posibilidad de recuperar llaves de cifrado o rastros de malware residente en memoria

LO QUE NO SE DEBE HACER

- Apagar o limpiar el equipo: Destruye la información que solo existe mientras el hardware tiene energía
- Manipular archivos directamente: Alterar el estado de la sesión borra la cronología exacta del incidente

CONCEPTO CLAVE

La evidencia volátil desaparece al cortar la energía; el orden de las acciones determina el éxito de la investigación.

ACCIONES CORRECTAS

- No tocar: Mantener el equipo en el estado en que se encontró para preservar la escena
- Captura de RAM: Realizar volcado de memoria siguiendo el orden de volatilidad (RFC 3227)
- Aislamiento de red: Desconectar el cable físico para detener exfiltración sin apagar el sistema

REFERENCIA NORMATIVA

- RFC 3227: Orden de volatilidad para recolección de evidencia
- ISO 27037: Directrices para identificación y preservación de evidencia digital
- Principio de Locard: Todo contacto deja rastro en el entorno digital

ESCENARIO

La Subteniente Gómez ingresa sus credenciales en un enlace falso recibido por correo. Durante 18 horas, su cuenta envía correos masivos de forma automática hasta que el área de TI detecta la anomalía.

ANÁLISIS DEL INCIDENTE

- Tipo de amenaza: Amenaza externa (Phishing) que compromete una cuenta interna
- Fase del ciclo de vida: El área de TI intervino en la fase de detección y contención

FALLAS IDENTIFICADAS

- Falta de reconocimiento: No se identificaron las señales de un enlace externo malicioso
- Latencia en la detección: El compromiso duró 18 horas sin ser advertido, permitiendo la sobreescritura de logs

CONCEPTO CLAVE

La forense digital permite reconstruir el alcance de la brecha tras el compromiso inicial de un usuario.

EVIDENCIAS DIGITALES

- Cabeceras de correo: Indispensables para rastrear el origen real del ataque
- Logs de autenticación: Registros de direcciones IP externas que accedieron a la cuenta institucional

LECCIONES APRENDIDAS

- Capacitación: Entrenar al personal en identificación de correos de phishing
- Monitoreo: Implementar alertas automáticas ante comportamiento anómalo de cuentas
- Preservación de logs: Asegurar retención de registros por período suficiente

ESCENARIO

El Capitán Herrera detecta un acceso fuera de horario al sistema de personal y le pide a Quispe que revise rápido. Quispe entra al servidor original, anota IPs en un papel a mano y cierra la sesión. Dos días después, los logs originales se borran automáticamente por rotación del sistema.

VIOLACIÓN DE PRINCIPIOS

- Integridad: El acceso directo al servidor pudo modificar los metadatos (timestamps) de los archivos de log
- Reproducibilidad: Las notas a mano no permiten que otro perito verifique si la información es exacta
- Trazabilidad: Al no preservar el log original mediante copia forense, se perdió el rastro digital permanente

ERRORES PROCEDIMENTALES

- Análisis sobre el original: Nunca se debe trabajar directamente sobre la fuente de la evidencia
- Falta de integridad técnica: No se calculó un valor Hash (SHA-256) para asegurar que el log no fue alterado

CONSECUENCIA

El caso queda cerrado por falta de pruebas válidas, ya que el reporte manual no tiene sustento forense científico.

CONCEPTO CLAVE

- Los principios de integridad, reproducibilidad y trazabilidad diferencian una pericia técnica de una simple opinión
- La evidencia debe ser recolectada siguiendo estándares ISO 27037 y verificada con funciones hash criptográficas

PROCEDIMIENTO CORRECTO

- Trabajar siempre sobre copia forense verificada, nunca sobre el sistema original
- Calcular hash SHA-256 de toda evidencia recolectada
- Documentar cada acción con fecha, hora y responsable
- Seguir cadena de custodia según norma ISO 27037

TABLA RESUMEN

Guía de referencia rápida para el manejo correcto de evidencia digital en investigaciones forenses.

SÍ SE DEBE HACER

- Manejo inicial: Documentar el estado inicial y tomar fotografías
- Análisis: Trabajar siempre sobre una copia forense verificada
- Recolección: Usar funciones Hash para garantizar la integridad
- Metodología: Seguir la cadena de custodia y la norma ISO 27037

NO SE DEBE HACER

- Manejo inicial: Apagar, cerrar sesiones o limpiar el escritorio
- Análisis: Acceder o navegar directamente en el sistema original
- Recolección: Copiar datos manualmente en papel o texto simple
- Metodología: Confiar en intuiciones o procesos no estandarizados

Conclusiones y Reflexiones Finales

- La informática forense es una disciplina esencial para la seguridad del Ejército del Perú en el ciberespacio.
- La correcta preservación de la evidencia digital es el pilar fundamental para la validez legal de toda investigación.
- El marco legal peruano proporciona las herramientas jurídicas necesarias; su conocimiento es obligatorio para el personal involucrado.
- La capacitación continua en respuesta a incidentes y análisis forense fortalece la postura de ciberdefensa institucional.
- Cada militar es un eslabón en la cadena de seguridad: la prevención empieza con la conciencia individual.